CURRENTSTATEASSESSMENT

OSCORP
STATO ATTUALE DELLA CYBER SECURITY

DOCUMENTO RISTRUTTURATO IN ITALIANO

Riorganizzazione professionale del contenuto fornito, mantenendo esclusivamente le informazioni presenti nel documento originale.

Documento	Oscorp - Stato attuale della Cyber Security
Lingua	Italiano
Fonte	Capstone_Oscorp_CurrentState.pdf
Nota	Ristrutturazione del contenuto esistente, senza aggiunte di analisi esterne

Uso: portfolio / documentazione di progetto

OSCORP - STATO ATTUALE DELLA CYBER SECURITY

1. Team cyber security attuale

Ruolo	Descrizione
Cyber Security Analyst	Profilo generalista; risponde agli incidenti cyber quando si verificano. Riporta all'IT Manager di Oscorp.
Network Engineer	Gestisce i firewall. Riporta al Network Team Leader.
Cyber Security Consultant	Nuovo ruolo in Oscorp. Inizialmente riporta all'IT Manager.

2. Controlli cyber security attuali

1. Governance organizzativa

• Il CEO ha una chiara strategia business per l'azienda.
• I ruoli e le responsabilità per la cyber security non sono stati definiti.
• Le responsabilità cyber security sono assegnate al team IT.
• Non è presente una strategia di cyber security.

2. Asset Management

• Il team IT dispone di uno spreadsheet con i numeri seriali dei laptop.
• Lo spreadsheet include il modello di ogni macchina e i dettagli relativi alla garanzia.
• Oscorp utilizza Microsoft Office 365 e si basa esclusivamente su applicazioni Software-as-a-Service.
• Tutti i dati si trovano nel cloud Microsoft Azure.
• Il team IT utilizza un Secure Operating Environment (SOE) per configurare tutti i laptop con l'ultima versione desktop di Windows.

3. Business Continuity e Disaster Recovery

• Il team IT svolge regolarmente test di disaster recovery.
• Il team IT dispone di piani di business continuity chiari e documentati.
• Il team IT esegue backup regolari.
• I backup vengono testati periodicamente.

4. Vulnerability Management

• Oscorp ha acquistato lo scanner di vulnerabilità Qualys.
• Il team IT utilizza Qualys su base ad hoc.
• Non è presente un programma formale di vulnerability management.
• Qualys segnala un numero elevato di vulnerabilità high e severe.

5. Risk Management

• Oscorp dispone di un team risk che svolge attività di financial risk.
• In Oscorp non è presente un processo di technology risk o cyber risk.

6. Third Party Risk Management

• Oscorp non svolge attività di third-party risk management.
• I contratti vengono revisionati da procurement e finance, non dall'IT.

7. Identity and Access Management

• Oscorp utilizza Microsoft Active Directory per gestire utenti e gruppi.
• Non è presente una soluzione di privileged access management.
• La password dell'account amministratore è condivisa con alcuni membri senior del team IT.
• L'accesso alle risorse viene concesso su richiesta.
• L'organizzazione non utilizza l'autenticazione a due fattori per il login.
• Vengono utilizzate password di accesso complesse.
• I dipendenti utilizzano una soluzione VPN per il login da remoto quando necessario.

8. Network Security

• L'organizzazione dispone di firewall Palo Alto Next Gen.
• I firewall sono stati configurati dal team network.
• I firewall vengono auditati ogni anno dal team network.
• I firewall ricevono aggiornamenti regolari.
• Il team IT dispone di diagrammi di rete aggiornati.
• I diagrammi includono l'ambiente cloud.
• La rete è segmentata tramite VLAN.

9. Physical Security

• Oscorp è una struttura altamente sicura, con telecamere CCTV all'avanguardia ovunque.
• Oscorp prende molto seriamente la sicurezza fisica.
• Viene svolta un'attività estesa di vetting per tutti i dipendenti.
• È presente monitoraggio 24/7 per i laboratori di ricerca e le facility fisiche.

10. Data Security

• Oscorp non dispone di una soluzione DLP.
• Tutti i dati risiedono nel cloud Microsoft Azure e in Microsoft Office 365.
• L'applicazione critica principale è un servizio SaaS di Horizon Labs.

11. Policy

• È presente una policy IT generica.
• Non è presente una policy formale di information security.
• Non sono presenti policy di data governance o information classification.

12. Cyber Security Detection and Response

• Non è presente una capacità di detection o response.
• Il team IT risponde agli alert dell'antivirus Microsoft Defender.
• Non è presente un SIEM.

13. Security Education and Awareness

- Tutti i dipendenti devono completare un modulo web di induction.
- Il modulo include istruzioni di base sulla cyber security.